CAPÍTULO 5

ORGANIZACIÓN DEL DEPARTAMENTO DE AUDITORÍA INFORMÁTICA

Rafael Ruano Díez

5.1. ANTECEDENTES

El concepto de auditoría informática ha estado siempre ligado al de auditoría en general y al de auditoría interna en particular, y éste ha estado unido desde tiempos históricos al de contabilidad, control, veracidad de operaciones, etc. En tiempo de los egipcios ya se hablaba de contabilidad y de control de los registros y de las operaciones. Aun algunos historiadores fijan el nacimiento de la escritura como consecuencia de la necesidad de registrar y controlar operaciones (Dale Flesher, *50 Years of Progress).* Hago esta referencia histórica a fin de explicar la evolución de la corta pero intensa historia de la auditoría informática, y para que posteriormente nos sirva de referencia al objeto de entender las diferentes tendencias que existen en la actualidad.

Si analizamos el nacimiento y la existencia de la auditoría informática desde un punto de vista empresarial, tendremos que empezar analizando el contexto organizativo y ambiental en el que se mueve.

Empezaremos diciendo que tanto dentro del contexto estratégico como del operativo de las organizaciones actuales, los sistemas de información y la arquitectura que los soporta desempeñan un importante papel como uno de los soportes básicos para la gestión y el control del negocio, siendo así uno de los requerimientos básicos de cualquier organización. Esto da lugar a los sistemas de información de una organización.

Es evidente que para que dichos sistemas cumplan sus objetivos debe existir una función de gestión de dichos sistemas, de los recursos que los manejan y de las

inversiones que se ponen a disposición de dichos recursos para que el funcionamiento y los resultados sean los esperados. Esto es lo que llamamos el Departamento de Sistemas de Información.

Finalmente, y en función de lo anterior, aunque no como algo no enteramente aceptado aún, debe existir una función de control de la gestión de los sistemas y del departamento de sistemas de información. A esta función la llamamos auditoría informática.

El concepto de la función de auditoría informática, en algunos casos llamada función de control informático y en los menos, llamada y conocida por ambos términos, arranca en su corta historia, cuando en los años cincuenta las organizaciones empezaron a desarrollar aplicaciones informáticas. En ese momento, la auditoría trataba con sistemas manuales. Posteriormente, en función de que las organizaciones empezaron con sistemas cada vez más complejos, se hizo necesario que parte del trabajo de auditoría empezara a tratar con sistemas que utilizaban sistemas informáticos.

En ese momento, los equipos de auditoría, tanto externos como internos, empezaron a ser mixtos, con involucración de auditores informáticos junto con auditores financieros. En ese momento se comenzaron a utilizar dos tipos de enfoque diferentes que en algunos casos convergían:

- Trabajos en los que el equipo de auditoría informática trabajaba bajo un programa de trabajo propio, aunque entroncando sus objetivos con los de la auditoría financiera; éste era el caso de trabajos en los que se revisaban controles generales de la instalación y controles específicos de las aplicaciones bajo conceptos de riesgo pero siempre unido al hecho de que el equipo de auditoría financiera utilizaría este trabajo para sus conclusiones generales sobre el componente financiero determinado.

- Revisiones en las que la auditoría informática consistía en la extracción de información para el equipo de auditoría financiera. En este caso el equipo o función de auditoría interna era un exponente de la necesidad de las organizaciones y departamentos de auditoría de utilizar expertos en informática para proveer al personal de dicho departamento de información extraída del sistema informático cuando la información a auditar estaba empezando a ser voluminosa y se estaba perdiendo la pista de cómo se había creado.

Esta situación convive hoy en día con conceptos más actuales y novedosos de lo que es la función y de lo que son los objetivos de la auditoría informática.

En mi opinión, y es algo que vamos a desarrollar a continuación, la tendencia futura de la auditoría informática radicará en los siguientes principios:

1. Todos los auditores tendrán que tener conocimientos informáticos que les permitan trabajar en el cada vez más fluctuante entorno de las tecnologías de la información dentro de las organizaciones empresariales, culturales y sociales.

2. Este aspecto no eliminará la necesidad de especialistas en auditoría informática; antes al contrario, los especialistas necesitarán cada vez más, unos conocimientos muy específicos, que al igual que sucede en el entorno de los sistemas de información, les permitan ser expertos en las diferentes ramas de la tecnología informática: comunicaciones, redes, ofimática, comercio electrónico, seguridad, gestión de bases de datos, etc.

3. El auditor informática dejará de ser un profesional procedente de otra área, con su consiguiente reciclado, para pasar a ser un profesional formado y titulado en auditoría informática que tendrá a su alcance diferentes medios de formación, externa fundamentalmente, y que tendrá que formar una red de conocimientos compartidos con otros profesionales, tanto en su organización como con profesionales de otras organizaciones.

El futuro de la auditoría informática estará en la capacidad de cubrir adecuadamente, en cuanto a experiencia y especialización, todas las áreas de los sistemas informáticos y de información de una empresa y en saber de forma propia o con ayuda interna y externa, adecuarse a los cambios que sucedan en la Tecnología de la Información. Para adecuarse a estos cambios, el auditor informático, tendrá que autogenerar su propia filosofía de gestión del cambio.

5.2. CLASES Y TIPOS DE AUDITORÍA INFORMÁTICA

Como he tratado de mencionar anteriormente, existe una gran confusión sobre lo que es auditoría informática y la relación que tiene con otras ramas organizativas de las empresas y organizaciones. Aun hoy en día, si preguntásemos a diferentes agentes empresariales y sociales, nos contestarían con diferentes respuestas sobre lo que es y no es auditoría informática.

Voy a tratar de resumir las diferentes acepciones de auditoría informática que existen en nuestro país:

- Auditoría informática como soporte a la auditoría tradicional, financiera, etc.

- Auditoría informática con el concepto anterior, pero añadiendo la función de auditoría de la función de gestión del entorno informático.

- Auditoría informática como función independiente, enfocada hacia la obtención de la situación actual de un entorno de información e informático en aspectos de seguridad y riesgo, eficiencia y veracidad e integridad.
- Las acepciones anteriores desde un punto de vista interno y externo.
- Auditoría como función de control dentro de un departamento de sistemas.

Ante esta situación déjenme expresar cuál es mi visión sobre lo que es y debe ser la función de auditoría informática.

5.3. FUNCIÓN DE AUDITORÍA INFORMÁTICA

5.3.1. Definición

Está claro a estas alturas que la auditoría, revisión, diagnóstico y control de los sistemas de información y de los sistemas informativos que soportan éstos deben ser realizados por personas con experiencia en ambas disciplinas, informática y auditoría (en principio llamemos a nuestro amigo el Auditor Informático General: AIG). A esto yo le añado que además nuestro amigo debe completar su formación con conocimientos de gestión del cambio y de gestión empresarial.

¿Cómo definimos entonces a nuestro amigo AIG? Para tratar de definir su perfil, la definición más exacta es quizá que es un profesional dedicado al análisis de sistemas de información e informáticos que está especializado en alguna de las múltiples ramas de la auditoría informática, que tiene conocimientos generales de los ámbitos en los que, ésta se mueve, que tiene conocimientos empresariales generales, y que además:

Posee las características necesarias para actuar como consultor con su auditado, dándole ideas de cómo enfocar la construcción de los elementos de control y de gestión que le sean propios.

Y que puede actuar como consejero con la organización en la que está desarrollando su labor. Un entorno informático bien controlado, puede ser un entorno ineficiente si no es consistente con los objetivos de la organización.

El eterno problema que se ha suscitado durante mucho tiempo es si el auditor informático, al no existir tal formación académica en nuestro país, tenía que ser un auditor convertido en informática, o por el contrario un informático reciclado como auditor informático. En mi larga experiencia, he visto de todo, personal de desarrollo o de explotación convertidos en auditores informáticos en menos de un mes, auditores financieros reciclados, primero como extractores de información, mediante la formación en el adecuado software de interrogación de archivos, y posteriormente convertidos en auditores de la función informática.

En ambos casos, los éxitos y los fracasos se acumulaban por igual. ¿Qué hacer en estos casos? ¿Cuál debe ser el perfil correcto de un auditor informático? Ésta es mi visión y opinión del perfil del futuro auditor informático y consecuentemente de las funciones que la función de auditoría informática debe tener.

5.3.2. Perfiles profesionales de la función de Auditoría Informática

A tenor de lo que hemos dicho hasta ahora, se ve claramente que el auditor informático debe ser una persona con un alto grado de calificación técnica y al mismo tiempo estar integrado en las corrientes organizativas empresariales que imperan hoy en día. De esta forma, dentro de la función de auditoría informática, se deben contemplar las siguientes características para mantener un perfil profesional adecuado y actualizado:

1. La persona o personas que integren esta función deben contemplar en su formación básica una mezcla de conocimientos de auditoría financiera y de informática general. Estos últimos deben contemplar conocimientos básicos en cuanto a:

   - Desarrollo informático; gestión de proyectos y del ciclo de vida de un proyecto de desarrollo.
   - Gestión del departamento de sistemas.
   - Análisis de riesgos en un entorno informático.
   - Sistema operativo (este aspecto dependerá de varios factores, pero principalmente de si va a trabajar en un entorno único –auditor interno– o, por el contrario, va a tener posibilidades de trabajar en varios entornos como auditor externo).
   - Telecomunicaciones.
   - Gestión de bases de datos.
   - Redes locales.
   - Seguridad física.
   - Operaciones y planificación informática; efectividad de las operaciones y del rendimiento de los sistemas.
   - Gestión de la seguridad de los sistemas y de la continuidad empresarial a través de planes de contingencia de la información.
   - Gestión de problemas y de cambios en entornos informáticos.
   - Administración de datos.

- Ofimática.
- Comercio electrónico.
- Encriptación de datos.

2. A estos conocimientos básicos se les deberá añadir una especialización en función de la importancia económica que distintos componentes financieros puedan tener en un entorno empresarial. Así, en un entorno financiero pueden tener mucha importancia las comunicaciones, y será necesario que alguien dentro de la función de auditoría informática tenga esta especialización, pero esto mismo puede no ser válido para un entorno productivo en el que las transacciones EDI pueden ser más importantes.

3. Uno de los problemas que más han incidido en la escasa presencia de auditores informáticos en nuestro país, es quizás la a veces escasa relación entre el trabajo de auditoría informática y las conclusiones con el entorno empresarial donde se ubicaba la "entidad auditada". Esta sensación de que las normas van por sitios diferentes de por donde va el negocio ha sido fruto muchas veces de la escasa comunicación entre el auditado (objetivos empresariales) y el auditor (objetivos de control). Como quiera que la cruda realidad nos está demostrando en la actualidad cada vez más la necesidad de cada vez mayor control en los sistemas de información, se hace necesario para el auditor informático conocer técnicas de gestión empresarial, y sobre todo de gestión del cambio, ya que las recomendaciones y soluciones que se aporten deben estar en la línea de la búsqueda óptima de la mejor solución para los objetivos empresariales que se persiguen y con los recursos que se tienen.

4. El auditor informático debe tener siempre el concepto de Calidad Total. Como parte de un colectivo empresarial, bien sea permanentemente como auditor interno o puntualmente como auditor externo, el concepto de calidad total hará que sus conclusiones y trabajo sea reconocido como un elemento valioso dentro de la organización y que los resultados sean aceptados en su totalidad. Esta aplicación organizativa debe hacer que la propia imagen del auditor informático sea más reconocida de forma positiva por la organización.

5.3.3. Funciones a desarrollar por la función de Auditoría Informática

Se han suscitado múltiples controversias sobre las funciones a desarrollar en cuanto al trabajo de Auditoría Informática que se debe realizar. ¿Cuál es el objetivo de una Auditoría Informática? ¿Qué se debe revisar, analizar o diagnosticar?

¿Puede la función de Auditoría Informática aportar sólo lo que le piden o debe formar parte de un ente organizativo total, lo que le exige una actitud de contribución total al entorno empresarial en el que está realizando su trabajo? En definitiva, ¿qué aspectos debe revisar el auditor informático? Debe revisar la seguridad, el control interno, la efectividad, la gestión del cambio y la integridad de la información.

Si analizamos la realidad más actual, diremos que la función Auditoría Informática debe mantener en la medida de lo posible los objetivos de revisión que le demande la organización, pero como esto es muy general, vamos a precisar algo más lo que sería un entorno ideal que tiene que ser auditado.

Supongamos una organización que produce componentes tecnológicos de audio y vídeo tanto en formato primario como en producto semiterminado y terminado. Esta organización mantiene sus programas y resultados de investigación bajo control informático. Además tiene las características propias de cualquier empresa productora y comercial en cuanto a sistemas de información. Mantiene en Internet un sistema de información de sus productos con la posibilidad de que usuarios de la Red puedan hacer consultas sobre diferentes características de los productos. Gasta anualmente un uno por ciento de su facturación en sus sistemas de información y un diez por ciento en investigación.

¿Cuáles serían los objetivos de revisión de la Auditoría Informática en este ejemplo? Desde luego parece que la Auditoría Informática debería enfocarse hacia aspectos de seguridad, de comercio electrónico y de control interno en general, añadiendo en función de lo expuesto en cuanto al gasto anual que debería realizarse una revisión de la efectividad del departamento.

Esto nos indica que solamente con un ejemplo simple vemos que la Auditoría Informática abarca campos de revisión más allá de los que tradicionalmente se han mantenido; esto es, la revisión del control interno informático de los servicios centrales y de las aplicaciones.

El mundo complejo de las empresas en el que nos movemos, con industrias emergentes y con una tendencia globalizadora en los negocios, hace muy necesario que los sistemas de control interno sean lo más efectivos posibles, pero también conceptos más amplios, como el riesgo de la información, la continuidad de las operaciones, la gestión del centro de información o la efectividad y actualización de las inversiones realizadas son necesarias para poder mantener el nivel competitivo que el mundo empresarial demanda a sus sistemas de información.

Es así que entonces la función de Auditoría Informática debe realizar un amplio abanico de actividades objetivas, algunas de las cuales enumero a continuación:

- Verificación del control interno, tanto de las aplicaciones como de los sistemas informáticos, centrales y periféricos.
- Análisis de la gestión de los sistemas de información desde un punto de vista de riesgo de seguridad, de gestión y de efectividad de la gestión.
- Análisis de la integridad, fiabilidad y certeza de la información a través del análisis de las aplicaciones. Esta función, que la vienen desempeñando los auditores informáticos, están empezando ya a desarrollarla los auditores financieros.
- Auditoría del riesgo operativo de los circuitos de información.
- Análisis de la gestión de los riesgos de la información y de la seguridad implícita.
- Verificación del nivel de continuidad de las operaciones (a realizar conjuntamente con los auditores financieros).
- Análisis del Estado del Arte tecnológico de la instalación revisada y de las consecuencias empresariales que un desfase tecnológico pueda acarrear.
- Diagnóstico sobre el grado de cobertura que dan las aplicaciones a las necesidades estratégicas y operativas de información de la organización.

El papel de la auditoría informática se convierte de esta manera en algo más que la clásica definición del auditor informático:

"... el auditor informático es responsable para establecer los objetivos de control que reduzcan o eliminen la exposición al riesgo de control interno. Después de que los objetivos de la auditoría se hayan establecido, el auditor debe revisar los controles y evaluar los resultados de su revisión para determinar las áreas que requieran correcciones o mejoras."

Aun a riesgo de ser criticado por muchos de mis compañeros, creo que el papel del auditor informático tiene que dejar de ser el de un profesional cuya única meta empresarial sea analizar el grado de implantación y cumplimiento del control interno. Las organizaciones están invirtiendo mucho dinero en sistemas de información, cada vez son más dependientes de ellos y no pueden permitirse el lujo de tener buenos profesionales, que estaban mediatizados por esquemas que eran válidos hace unos años pero que en estos momentos no lo son a tenor de las necesidades empresariales. El concepto de control interno es importantísimo, pero además de verificar dicho control, el auditor interno tiene la obligación de convertirse un poco en consultor y en ayuda del auditado, dándole ideas de cómo establecer procedimientos de seguridad, control interno, efectividad y eficacia y medición del riesgo empresarial.

5.4. ORGANIZACIÓN DE LA FUNCIÓN DE AUDITORÍA INFORMÁTICA

Según lo que hemos comentado hasta ahora, la función de auditoría informática ha pasado de ser una función meramente de ayuda al auditor financiero a ser una función que desarrolla un trabajo y lo seguirá haciendo en el futuro, más acorde con la importancia que para las organizaciones tienen los sistemas informáticos y de información que son su objeto de estudio y análisis. El auditor informático pasa a ser auditor y consultor del ente empresarial, en el que va a ser analista, auditor y asesor en materias de:

- Seguridad
- Control interno operativo
- Eficiencia y eficacia
- Tecnología informática
- Continuidad de operaciones
- Gestión de riesgos

no solamente de los sistemas informáticos objeto de su estudio, sino de las relaciones e implicaciones operativas que dichos sistemas tienen en el contexto empresarial.

Con esta amplitud de miras, ¿cómo se va a organizar la función dentro de la empresa? Está claro que en este caso estamos hablando de una función interna de auditoría informática.

La concepción típica que he visto en las empresas españolas hasta ahora, es la de que la función de auditoría informática está entroncada dentro de lo que es la función de auditoría interna con rango de subdepartamento. Esta concepción se basa en el nacimiento histórico de la auditoría informática y en la dificultad de separar el elemento informático de lo que es la auditoría operativa y financiera, al igual que lo es separar la operativa de una empresa de los sistemas de información que los soportan.

Si volvemos a mi aseveración anterior sobre el papel que debe desempeñar el auditor informático dentro de un contexto empresarial, la organización tipo de la auditoría informática, debe contemplar en mi opinión los siguientes principios:

- Su localización puede estar ligada a la localización de la auditoría interna operativa y financiera, pero con independencia de objetivos (aunque haya una coordinación lógica entre ambos departamentos), de planes de formación y de presupuestos.

- La organización operativa tipo debe ser la de un grupo independiente del de auditoría interna, con una accesibilidad total a los sistemas informáticos y de información, e idealmente dependiendo de la misma persona en la empresa que la auditoría interna, que debería ser el director general o consejero delegado. Cualquier otra dependencia puede dar al traste con la imagen del auditor informático y consecuentemente con la aceptación de su trabajo y de sus conclusiones.

La dependencia, en todo caso, debe ser del máximo responsable operativo de la organización, nunca del departamento de organización o del de sistemas (abundan los casos en que esta dependencia existe), ni del departamento financiero y/o administrativo.

La gestión de la función, en la medida de que exista la experiencia, debe ser llevada a cabo por personal que haya o esté trabajando en auditoría informática.

Los recursos humanos con los que debe contar el departamento deben contemplar una mezcla equilibrada entre personas con formación en auditoría y organización y personas con perfil informático. No obstante, este perfil genérico debe ser tratado con un amplio programa de formación en donde se especifiquen no sólo los objetivos de la función, sino también de la persona.

- Este personal debe contemplar entre su titulación la de CISA como un elemento básico para comenzar su carrera como auditor informático.

- La organización interna tipo de la función podría ser:

  - Jefe del departamento. Desarrolla el plan operativo del departamento, las descripciones de los puestos de trabajo del personal a su cargo, las planificaciones de actuación a un año, los métodos de gestión del cambio en su función y los programas de formación individualizados, así como gestiona los programas de trabajo y los trabajos en sí, los cambios en los métodos de trabajo y evalúa la capacidad de las personas a su cargo.

  - Gerente o supervisor de auditoría informática. Trabaja estrechamente con el Jefe del departamento en las tareas operativas diarias. Ayuda en la evaluación del riesgo de cada uno de los trabajos, realiza los programas de trabajo, dirige y supervisa directamente a las personas en cada uno de los trabajos de los que es responsable. Realiza la formación sobre el trabajo. Es responsable junto con su jefe de la obtención del mejor resultado del trabajo para el auditado, entroncando los conceptos de valor añadido y gestión del cambio dentro de su trabajo. Es el que más "vende" la función con el auditado.

- Auditor informático. Son responsables para la ejecución directa del trabajo. Deben tener una especialización genérica, pero también una específica, según se comentó anteriormente. Su trabajo consistirá en la obtención de información, realización de pruebas, documentación del trabajo, evaluación y diagnóstico de resultados.

- El tamaño sólo se puede precisar en función de los objetivos de la función, pero en mi opinión, para una organización tipo, el abanico de responsabilidades debería cubrir:

  - Especialista en el entorno informático a auditar y en gestión de bases de datos.
  - Especialista en comunicaciones y/o redes.
  - Responsable de gestión de riesgo operativo y aplicaciones.
  - Responsable de la auditoría de sistemas de información, tanto en explotación como en desarrollo.
  - En su caso, especialista para la elaboración de programas de trabajo conjuntos con la Auditoría Financiera.

5.5. CUESTIONES DE REPASO

1. ¿Cuáles son las líneas de evolución de la Auditoría Informática?

2. ¿Qué diferentes acepciones existen de la Auditoría Informática?

3. ¿Cuál es el perfil del auditor informático general?

4. ¿Qué formación debe poseer el auditor informático?

5. ¿Cuáles son las funciones de la Auditoría Informática?

6. ¿Qué aspectos pueden hacer más compleja, en la actualidad, la función de Auditoría Informática?

7. ¿Cuál debe ser la localización de la función de Auditoría Informática en la empresa?

8. ¿Cuáles son las tareas del Jefe del Departamento de Auditoría Informática?

9. ¿Qué tamaño debe tener el Departamento de Auditoría Informática?

10. Defina un plan de formación para que un informático pueda desempeñar sin problemas la función de auditor.